

BOB-142 “ SearchRequest field bounds: closure evidence

Revision: 1 Last modified: 2026-08-20T16:15:00Z

RED (test written first, observed failing)

tests/security/test_search_request_bounds.py, run against the unbounded model:

```
FAILED test_oversized_query_is_refused
FAILED test_oversized_sort_fields_are_refused
FAILED test_oversized_tracker_filter_is_refused
FAILED test_oversized_category_is_refused
4 failed, 2 passed
```

The 2 that passed are the “§11.4.201(1) CONTROLS” a realistic query and a 3-tracker filter must still be accepted. They passed before the fix, proving the suite cannot be satisfied by a validator that simply refuses everything.

GREEN

6 passed, 1 warning in 4.93s

Live end-user evidence (“§11.4.108 layer 4” real HTTP, no test harness)

Against the running merge service on :7187 after ./start.sh --reload-python:

```
$ curl -X POST localhost:7187/api/v1/search -d '{"query":"<100,000 chars>"}'
-> HTTP 422
{"detail":[{"type":"string_too_long","loc":["body","query"],
      "msg":"String should have at most 256 characters", ...}]}

$ curl -X POST localhost:7187/api/v1/search -d '{"query":"interstellar 2014 1080p"}'
-> HTTP 200
{"search_id":"c110659c-382f-461c-be28-f723022bacbc",
 "query":"interstellar 2014 1080p","status":"running",
 "trackers_searched":["rutracker","kinozal","n...

$ curl -X POST localhost:7187/api/v1/search -d '{"query":"ok","trackers":["rutracker","kinozal","n..."]}'
-> HTTP 422
```

Both directions on the real user path: the amplification vector is refused, and a legitimate search still returns a real search_id with a real tracker set.

Regression

```
252 passed (tests/unit/test_merge_api_route_contracts.py, tests/unit/api
           tests/unit/test_rate_limit.py, tests/contract/test_openapi_co
           tests/security/test_search_request_bounds.py,
           tests/security/test_rate_limit_public_endpoints.py)
```

Full tests/security/: 117 passed, 33 skipped, 0 failed.

Bound sizing (evidence, not taste)

field	bound	measured basis
query	256	longest legitimate query in the repo is 14 chars (boba-111-probe)
category	64	longest is boundary-max-length-url (23)
sort_by / sort_order	32	enum-like values, longest observed well under 16
trackers	64 entries	43 managed plugins “a longer list is noise or an attempt

Relationship to rate limiting (BOB-111)

Complementary, not redundant. Rate limiting caps the request RATE; these bounds cap the per-request COST. A client inside its rate allowance could still send a multi-megabyte query into a 43-tracker fan-out, so neither control substitutes for the other.